

MEDISAFE LTD

Information Security Policy Framework

ISO/IEC 27001:2022 Aligned

Version: 1.0

Date: January 2026

Prepared by: Bhuvana Kodathi Srinivas

Approved by: Chief Executive Officer, MediSafe Ltd

Classification: Confidential

DOCUMENT CONTROL

Version	Date	Author	Changes
1.0	January 2026	Bhuvana Kodathi Srinivas	Initial document creation

TABLE OF CONTENTS

DOCUMENT CONTROL	2
TABLE OF CONTENTS.....	3
EXECUTIVE SUMMARY	5
Current Compliance Status	5
Priority Findings	5
Critical	5
High Priority	5
Recommended Next Steps	5
COMPANY PROFILE — MEDISAFE LTD.....	7
Company Overview	7
ISMS Scope	7
Data Classification	7
Asset Inventory	7
A.5 — ORGANISATIONAL CONTROLS	8
A.5.1 — Policies for Information Security	8
A.5.19 — Information Security in Supplier Relationships	8
A.5.20 — Addressing Security Within Supplier Agreements	8
A.6 — PEOPLE CONTROLS.....	9
A.6.1 — Screening.....	9
A.6.2 — Terms and Conditions of Employment	9
A.6.3 — Information Security Awareness, Education and Training	9
A.6.4 — Disciplinary Process.....	9
A.6.5 — Responsibilities After Termination or Change of Employment.....	10
A.6.6 — Confidentiality or Non Disclosure Agreements	10
A.6.7 — Remote Working.....	10
A.6.8 — Information Security Event Reporting	10
A.7 — PHYSICAL CONTROLS.....	12
A.7.1 — Physical Security Perimeters.....	12
A.7.2 — Physical Entry	12
A.7.3 — Securing Offices, Rooms and Facilities	12
A.7.4 — Physical Security Monitoring.....	12
A.7.5 — Protecting Against Physical and Environmental Threats	13
A.7.6 — Working in Secure Areas	13
A.7.7 — Clear Desk and Clear Screen.....	13
A.7.8 — Equipment Siting and Protection	13
A.7.9 — Security of Assets Off Premises.....	14
A.7.10 — Storage Media	14
A.7.11 — Supporting Utilities	14
A.7.12 — Cabling Security.....	14

A.7.13 — Equipment Maintenance	15
A.7.14 — Secure Disposal or Re use of Equipment	15
A.8 — TECHNOLOGICAL CONTROLS	16
A.8.1 — User Endpoint Devices.....	16
A.8.2 — Privileged Access Rights	16
A.8.3 — Information Access Restriction.....	16
A.8.4 — Access to Source Code.....	16
A.8.5 — Secure Authentication	17
A.8.6 — Capacity Management.....	17
A.8.7 — Protection Against Malware.....	17
A.8.8 — Management of Technical Vulnerabilities	18
A.8.9 — Configuration Management	18
A.8.10 — Information Deletion.....	18
A.8.11 — Data Masking.....	18
A.8.12 — Data Leakage Prevention	19
A.8.13 — Information Backup	19
A.8.14 — Redundancy of Information Processing Facilities.....	19
A.8.15 — Logging.....	19
A.8.16 — Monitoring Activities	20
A.8.17 — Clock Synchronisation	20
A.8.18 — Use of Privileged Utility Programs	20
A.8.19 — Installation of Software on Operational Systems	20
A.8.20 — Network Security	21
A.8.21 — Security of Network Services.....	21
A.8.22 — Segregation of Networks.....	21
A.8.23 — Web Filtering	21
A.8.24 — Use of Cryptography	22
A.8.25 — Secure Development Lifecycle	22
A.8.26 — Application Security Requirements	22
A.8.27 — Secure System Architecture and Engineering Principles	22
A.8.28 — Secure Coding.....	23
A.8.29 — Security Testing in Development and Acceptance.....	23
A.8.30 — Outsourced Development.....	23
A.8.31 — Separation of Development, Test and Production Environments.....	23
A.8.32 — Change Management.....	24
A.8.33 — Test Information.....	24
A.8.34 — Protection of Information Systems During Audit Testing	24
GLOSSARY	25

EXECUTIVE SUMMARY

This Information Security Policy Framework has been developed for MediSafe Ltd in alignment with ISO/IEC 27001:2022. It establishes the governance structure, policies, and controls required to protect the confidentiality, integrity, and availability of MediSafe's information assets -including sensitive patient health data processed through its cloud -hosted digital health platform.

The framework covers all four ISO 27001:2022 Annex A control themes: Organisational Controls (A.5), People Controls (A.6), Physical Controls (A.7), and Technological Controls (A.8), encompassing 58 controls assessed across MediSafe's systems, staff, and operations.

Current Compliance Status

Status	Count	Percentage
Compliant	41	71%
Partially Compliant	9	15%
Non Compliant	8	14%
Total Controls Assessed	58	100%

Overall Compliance Score: 71%

MediSafe Ltd has established a solid information security foundation with strong controls in place across access management, encryption, backup, logging, network security, and physical security. However, several gaps require prioritised remediation before the organisation can pursue formal ISO 27001 certification.

Priority Findings

Critical

- A.8.8 - Vulnerability Management: No formal vulnerability scanning programme exists. Monthly automated scans must be implemented immediately using AWS Inspector.
- A.8.11 — Data Masking: Live patient data has been used in development and testing environments. Data masking must be enforced immediately across all non production environments.

High Priority

- A.5.7 — Threat Intelligence: No formal process for monitoring healthcare sector threats. Subscription to CERT EU and NCSC Ireland threat feeds is recommended.
- A.5.35 — Independent Review: No independent ISMS audit has been conducted. An independent audit should be scheduled within the next 6 months.
- A.6.3 — Security Training: Annual security awareness training has not been consistently delivered. A formalised annual training programme with tracked completion records must be implemented.
- A.6.4 — Disciplinary Process: No formal disciplinary process exists for security violations. A documented procedure aligned to Irish employment law must be developed.
- A.8.12 — Data Leakage Prevention: No DLP tooling is currently deployed. A DLP solution must be evaluated and implemented.
- A.8.23 — Web Filtering: No web filtering is in place. DNS based web filtering must be deployed across all corporate network traffic.
- A.8.29 — Penetration Testing: No formal penetration test has been conducted. An annual penetration test by a qualified third party provider must be scheduled.

Recommended Next Steps

- Immediately remediate the two critical findings (A.8.8 and A.8.11) — these represent the highest risk to patient data security.

- Develop and implement the missing policies and procedures for high priority gaps within 90 days.
- Schedule an independent ISMS audit within 6 months to assess readiness for formal certification.
- Engage an accredited certification body to begin the formal ISO 27001 certification process once critical and high priority gaps are remediated.

COMPANY PROFILE — MEDISAFE LTD

Company Overview

MediSafe Ltd is a Dublin based healthcare technology startup with 50 employees, providing a cloud hosted digital health platform that connects patients with healthcare providers. The platform supports symptom checking, appointment booking, and secure messaging between patients and clinicians.

ISMS Scope

Area	Description
Infrastructure	AWS hosted production environment (EU region), VPC with firewall controlled access
Software	Web and mobile patient application, internal admin dashboard, Python and PostgreSQL
People	Engineering, Clinical Operations, Customer Support, People Operations; Information Security Officer
Data	Patient health records, appointment data, messaging logs, payment details
Procedures	Policies across all four ISO 27001:2022 Annex A control themes

Data Classification

Classification	Definition	Examples
Customer Confidential	Sensitive data belonging to patients or clients	Patient health records, appointment data, payment details
Company Confidential	Internal business information	Financial data, staff records, source code, contracts
Public	Information approved for public release	Marketing materials, published product documentation

Asset Inventory

No.	Asset	Classification	Owner
1	AWS hosted patient database	Customer Confidential	IT Department
2	Patient facing web application	Customer Confidential	Engineering Lead
3	Patient facing mobile application	Customer Confidential	Engineering Lead
4	Employee laptops and devices	Company Confidential	IT Department
5	GitHub source code repositories	Company Confidential	Engineering Lead
6	Internal Slack workspace	Company Confidential	IT Department
7	Payment processing API	Customer Confidential	Engineering Lead
8	Employee HR records system	Company Confidential	People Operations
9	Office Wi Fi network	Company Confidential	IT Department
10	Backup and disaster recovery systems	Company Confidential	IT Department

A.5 ORGANISATIONAL CONTROLS

A.5.1 Policies for Information Security

Purpose: To establish MediSafe Ltd's commitment to protecting the confidentiality, integrity, and availability of information assets, including patient health data, in accordance with ISO/IEC 27001:2022 and applicable regulatory requirements (GDPR, HIPAA where applicable).

Scope: This policy applies to all MediSafe Ltd employees, contractors, and third parties who access, process, or store company or patient information.

Policy Statement: MediSafe Ltd maintains a documented Information Security Management System (ISMS) that governs how information assets are protected. All staff must complete information security awareness training upon onboarding and annually thereafter. This policy framework is reviewed at planned intervals or following significant organisational or regulatory changes.

Responsibilities: The Information Security Officer owns this policy and is responsible for its implementation, review, and enforcement across the organisation.

Review Date: Annually, next review January 2027.

A.5.19 Information Security in Supplier Relationships

Purpose: To ensure that third party suppliers and vendors who access, process, or store MediSafe Ltd's information assets — including patient health data — maintain an adequate level of information security throughout the relationship.

Scope: This policy applies to all third-party suppliers, contractors, cloud service providers, and business partners who have access to MediSafe's systems, networks, or data — including but not limited to AWS, payment processing providers, software vendors, and any subcontractors engaged by primary suppliers.

Policy Statement: MediSafe Ltd requires all suppliers to undergo a formal security assessment prior to onboarding. Security requirements must be agreed upon contractually before access is granted. Supplier compliance is reviewed annually, and any identified gaps must be remediated within an agreed timeframe. MediSafe reserves the right to audit supplier security controls at any time.

Responsibilities: The Information Security Officer oversees supplier security assessments. Procurement and Legal teams ensure security clauses are included in all supplier contracts.

Review Date: Annually, next review January 2027.

A.5.20 Addressing Security Within Supplier Agreements

Purpose: To ensure that information security requirements are formally documented and agreed upon in all contracts with third party suppliers who access, process, or store MediSafe Ltd's information assets.

Scope: This policy applies to all supplier contracts, service agreements, and memoranda of understanding where a third party has access to MediSafe's systems, data, or physical premises — including cloud providers, payment processors, software vendors, and subcontractors.

Policy Statement: All supplier agreements must include: data protection and confidentiality obligations aligned to GDPR; incident notification requirements (within 24 hours of any suspected breach); the right for MediSafe to audit supplier security controls; defined data handling, retention, and deletion obligations; subcontractor restrictions requiring MediSafe approval; and consequences for non compliance including contract termination rights.

Responsibilities: The Legal team ensures security clauses are included in all contracts. The Information Security Officer reviews and approves supplier agreement security requirements before signing.

Review Date: Annually, next review January 2027.

A.6 PEOPLE CONTROLS

A.6.1 Screening

Purpose: To ensure that all individuals employed by MediSafe Ltd are trustworthy and suitable for their role, particularly given the sensitive nature of patient health data handled by the organisation.

Scope: Applies to all prospective employees, contractors, and third party personnel prior to being granted access to MediSafe systems, premises, or data.

Policy Statement: MediSafe Ltd conducts background checks on all new hires before employment commences. Checks include identity verification, employment history, and criminal record checks where legally permitted under Irish law. Results are treated confidentially and assessed in proportion to the role's level of data access.

Responsibilities: People Operations team owns the screening process. The Information Security Officer reviews screening outcomes for roles with elevated data access.

Review Date: Annually, next review January 2027.

A.6.2 Terms and Conditions of Employment

Purpose: To ensure all MediSafe staff understand and formally accept their information security responsibilities as a condition of employment.

Scope: Applies to all employees, contractors, and temporary staff before commencing work at MediSafe Ltd.

Policy Statement: All employment contracts and contractor agreements must include clauses covering confidentiality obligations, acceptable use of MediSafe systems and data, GDPR responsibilities, and consequences for policy violations. Staff must sign and acknowledge these terms before being granted system access.

Responsibilities: People Operations is responsible for ensuring security clauses are included in all contracts. Legal reviews contract templates annually.

Review Date: Annually, next review January 2027.

A.6.3 Information Security Awareness, Education and Training

Purpose: To ensure all MediSafe staff have the knowledge and skills to fulfil their information security responsibilities and protect patient data.

Scope: Applies to all employees, contractors, and third parties with access to MediSafe systems or data.

Policy Statement: All new staff must complete information security awareness training within their first week of employment. Refresher training is mandatory annually for all staff. Training covers MediSafe's security policies, GDPR obligations, phishing and social engineering awareness, password hygiene, and how to report suspected security incidents. Completion records are maintained by People Operations.

Responsibilities: The Information Security Officer designs and maintains the training programme. People Operations tracks completion and escalates non compliance.

Review Date: Annually, next review January 2027.

A.6.4 Disciplinary Process

Purpose: To ensure that information security policy violations are addressed consistently and proportionately across MediSafe Ltd.

Scope: Applies to all employees and contractors who violate MediSafe's information security policies.

Policy Statement: MediSafe Ltd maintains a formal disciplinary process for information security violations. Sanctions range from informal warnings for minor breaches to immediate termination for serious violations — such as unauthorised access to patient data, deliberate data exfiltration, or wilful circumvention of security controls. All violations are documented and investigated before sanctions are applied. The disciplinary process complies with Irish employment law.

Responsibilities: People Operations leads disciplinary proceedings in consultation with the Information Security Officer and Legal team.

Review Date: Annually, next review January 2027.

A.6.5 Responsibilities After Termination or Change of Employment

Purpose: To protect MediSafe Ltd's information assets when an employee's role changes or their employment ends.

Scope: Applies to all departing employees, contractors, and staff changing roles within MediSafe Ltd.

Policy Statement: All system access must be revoked within 24 hours of an employee's departure or role change. Company owned devices, access tokens, and credentials must be returned or deactivated on the final working day. Departing staff are reminded of their ongoing confidentiality obligations, which survive termination of employment. Exit interviews include a formal security briefing.

Responsibilities: People Operations initiates the offboarding checklist. IT is responsible for revoking access. The Information Security Officer verifies completion within 48 hours.

Review Date: Annually, next review January 2027.

A.6.6 Confidentiality or Non-Disclosure Agreements

Purpose: To protect MediSafe Ltd's confidential information — including patient data, proprietary systems, and business strategy — through legally binding confidentiality agreements.

Scope: Applies to all employees, contractors, consultants, and third parties before being granted access to MediSafe's confidential information.

Policy Statement: All staff and third parties must sign a Non Disclosure Agreement (NDA) before accessing MediSafe's confidential information. NDAs cover patient health data, business sensitive information, proprietary software, and unpublished strategies. NDAs remain in force after the termination of employment or contract. Legal reviews NDA templates annually.

Responsibilities: Legal team manages NDA templates and tracks signatures. People Operations ensures NDAs are signed before system access is granted.

Review Date: Annually, next review January 2027.

A.6.7 Remote Working

Purpose: To ensure that information security standards are maintained when MediSafe staff work outside the office environment.

Scope: Applies to all MediSafe employees and contractors working remotely or in hybrid arrangements.

Policy Statement: All remote working must comply with MediSafe's Remote Working Security Policy. Staff must use MediSafe approved devices and connect via VPN when accessing internal systems. Patient data must not be accessed on personal devices unless explicitly approved by the Information Security Officer. Staff must use secure, password protected Wi Fi networks and must not work in public spaces where screens are visible to others.

Responsibilities: The Information Security Officer maintains and enforces the Remote Working Security Policy. IT provides and manages VPN access for all remote staff.

Review Date: Annually, next review January 2027.

A.6.8 Information Security Event Reporting

Purpose: To ensure that all suspected information security events are reported promptly so that MediSafe Ltd can respond effectively and meet its regulatory notification obligations.

Scope: Applies to all employees, contractors, and third parties with access to MediSafe systems or data.

Policy Statement: All staff must report suspected security events immediately upon detection — including phishing emails, lost or stolen devices, unusual system behaviour, or suspected unauthorised access. Reports must be made to the Information Security Officer via the dedicated security reporting channel

(security@medisafe.ie). Anonymous reporting is permitted. MediSafe will not penalise staff who report incidents in good faith.

Responsibilities: The Information Security Officer receives and triages all reported security events. All staff are responsible for reporting suspected incidents without delay.

Review Date: Annually, next review January 2027.

A.7 PHYSICAL CONTROLS

A.7.1 Physical Security Perimeters

Purpose: To protect MediSafe Ltd's office premises and secure areas from unauthorised physical access.

Scope: Applies to all MediSafe office locations, secure rooms, and any areas where sensitive information or systems are stored.

Policy Statement: MediSafe Ltd defines clear physical security perimeters around its Dublin office. Entry points are controlled and monitored. All staff must display their access badge at all times while on premises. Secure areas — including server rooms or filing rooms containing patient records — are separately controlled with restricted access.

Responsibilities: Facilities Manager maintains physical perimeter controls. The Information Security Officer conducts annual physical security reviews.

Review Date: Annually, next review January 2027.

A.7.2 Physical Entry

Purpose: To ensure only authorised individuals can enter MediSafe Ltd's office and secure areas.

Scope: Applies to all staff, contractors, visitors, and third parties seeking access to MediSafe premises.

Policy Statement: Access to MediSafe's Dublin office is controlled via key card entry. All visitors must sign in at reception, state their purpose, and be escorted by a named MediSafe staff member at all times. Visitor access logs are retained for a minimum of 12 months. Contractors requiring access to secure areas must be pre approved by the Information Security Officer. Key cards are deactivated immediately upon staff departure.

Responsibilities: Facilities Manager maintains the access control system and visitor logs. People Operations notifies IT of any staff departures requiring immediate deactivation.

Review Date: Annually, next review January 2027.

A.7.3 Securing Offices, Rooms and Facilities

Purpose: To protect MediSafe Ltd's sensitive areas from unauthorised access, theft, and damage.

Scope: Applies to all MediSafe office areas, secure rooms, and storage facilities containing sensitive information or equipment.

Policy Statement: All secure areas — including server rooms, filing rooms, and areas storing patient records — must be locked when not in use. Access is restricted to named individuals approved by the Information Security Officer. Keys and access codes are not shared and are changed when a staff member with access leaves the organisation. Physical documents containing patient data are stored in locked cabinets.

Responsibilities: Facilities Manager maintains physical locking mechanisms. The Information Security Officer reviews the list of individuals with access to secure areas quarterly.

Review Date: Annually, next review January 2027.

A.7.4 Physical Security Monitoring

Purpose: To detect and deter unauthorised physical access to MediSafe Ltd's premises and secure areas.

Scope: Applies to all MediSafe office locations and secure areas.

Policy Statement: MediSafe Ltd maintains CCTV surveillance covering all entry and exit points and secure areas. CCTV footage is retained for a minimum of 30 days and reviewed following any suspected security incident. Alarm systems are installed and tested quarterly. CCTV and alarm systems comply with GDPR requirements for surveillance data.

Responsibilities: Facilities Manager oversees CCTV and alarm systems. The Information Security Officer reviews surveillance logs following any reported incident.

Review Date: Annually, next review January 2027.

A.7.5 Protecting Against Physical and Environmental Threats

Purpose: To protect MediSafe Ltd's office, equipment, and information assets from physical and environmental hazards.

Scope: Applies to all MediSafe office locations and equipment.

Policy Statement: MediSafe Ltd takes reasonable measures to protect its premises and equipment from environmental threats including fire, flood, power failure, and extreme temperatures. Fire suppression systems and smoke detectors are installed and tested regularly. UPS systems protect critical office equipment. AWS is responsible for environmental controls within its data centres — MediSafe reviews AWS's SOC 2 report annually as evidence of compliance.

Responsibilities: Facilities Manager maintains environmental protection systems. The Information Security Officer reviews AWS environmental controls annually via the AWS SOC 2 report.

Review Date: Annually, next review January 2027.

A.7.6 Working in Secure Areas

Purpose: To ensure that work conducted in MediSafe Ltd's secure areas is performed safely and without risk of unauthorised exposure of sensitive information.

Scope: Applies to all staff, contractors, and visitors with access to MediSafe's secure areas.

Policy Statement: Only authorised personnel may work in MediSafe's secure areas. Visitors are not permitted in secure areas without prior approval and must be escorted at all times. Photography and recording are prohibited in secure areas. Sensitive conversations involving patient data must not take place in areas where they could be overheard by unauthorised individuals.

Responsibilities: The Information Security Officer defines and enforces secure area working rules. Facilities Manager controls physical access.

Review Date: Annually, next review January 2027.

A.7.7 Clear Desk and Clear Screen

Purpose: To prevent unauthorised access to sensitive information left unattended on desks or screens within MediSafe Ltd's premises.

Scope: Applies to all MediSafe employees and contractors working on site or remotely.

Policy Statement: All staff must follow a clean desk policy — sensitive documents and patient data must be locked away when not in use and must never be left unattended on desks. Screens must lock automatically after 5 minutes of inactivity. Printouts containing patient or confidential data must be collected from printers immediately and shredded using cross cut shredders when no longer needed. Whiteboards containing sensitive information must be erased after meetings.

Responsibilities: All staff are responsible for complying with the clear desk and clear screen policy. Line managers are responsible for monitoring compliance within their teams.

Review Date: Annually, next review January 2027.

A.7.8 Equipment Siting and Protection

Purpose: To protect MediSafe Ltd's equipment from unauthorised access, damage, and visual exposure of sensitive information.

Scope: Applies to all MediSafe office equipment including computers, monitors, printers, and servers.

Policy Statement: Monitors and screens must be positioned to prevent unauthorised viewing — screens in open plan areas must face away from public walkways and windows. Equipment in high traffic areas must be physically secured to desks using cable locks. Printers handling sensitive documents must be located in restricted areas. IT equipment must not be moved or relocated without IT department approval.

Responsibilities: IT department is responsible for equipment siting decisions. Facilities Manager ensures cable locks and physical security measures are in place.

Review Date: Annually, next review January 2027.

A.7.9 Security of Assets Off Premises

Purpose: To protect MediSafe Ltd's information assets when equipment is used or transported outside the office.

Scope: Applies to all MediSafe owned devices used off premises including laptops, mobile phones, tablets, and storage devices.

Policy Statement: All MediSafe owned devices must be encrypted before being taken off premises. Staff must not leave devices unattended in vehicles, public spaces, or unsecured locations. Devices must be kept in carry on baggage when travelling. Any lost or stolen device must be reported to the Information Security Officer immediately so remote wipe can be initiated.

Responsibilities: IT department manages device encryption and MDM enrollment. All staff are responsible for the physical security of devices in their possession.

Review Date: Annually, next review January 2027.

A.7.10 Storage Media

Purpose: To ensure that storage media containing MediSafe Ltd's information assets are managed, protected, and disposed of securely.

Scope: Applies to all storage media used by MediSafe — including USB drives, external hard drives, backup media, and SD cards.

Policy Statement: All storage media containing MediSafe or patient data must be encrypted and tracked in the asset register. Use of personal USB drives on MediSafe systems is prohibited. Backup media is stored securely off site and tested quarterly. When storage media reaches end of life, data must be securely wiped using certified methods or physically destroyed. Disposal certificates must be obtained and retained for audit purposes.

Responsibilities: IT department manages the storage media register and disposal process. The Information Security Officer reviews media disposal records annually.

Review Date: Annually, next review January 2027.

A.7.11 Supporting Utilities

Purpose: To protect MediSafe Ltd's office infrastructure from utility failures that could impact the availability of information systems.

Scope: Applies to power, cooling, and connectivity infrastructure supporting MediSafe's Dublin office.

Policy Statement: MediSafe Ltd maintains UPS systems for critical office equipment to protect against power interruptions. Internet connectivity is provided via a primary and backup connection to ensure continuity. AWS manages all utility infrastructure within its data centres — MediSafe reviews AWS's SOC 2 report annually as evidence.

Responsibilities: Facilities Manager maintains office utility infrastructure. IT department monitors connectivity and manages failover procedures.

Review Date: Annually, next review January 2027.

A.7.12 Cabling Security

Purpose: To protect MediSafe Ltd's network and power cabling from damage, interference, and unauthorised interception.

Scope: Applies to all network and power cabling within MediSafe's Dublin office.

Policy Statement: All network cabling within MediSafe's office is installed and maintained by qualified IT staff or certified contractors. Cable runs in secure areas are documented and regularly inspected. Unauthorised connections to MediSafe's network infrastructure are strictly prohibited. AWS manages all cabling within its data centres.

Responsibilities: IT department maintains cabling documentation and conducts annual inspections. Facilities Manager ensures physical protection of cable runs.

Review Date: Annually, next review January 2027.

A.7.13 Equipment Maintenance

Purpose: To ensure MediSafe Ltd's equipment remains operational and secure through regular maintenance and controlled repair processes.

Scope: Applies to all MediSafe owned equipment including laptops, servers, printers, and networking equipment.

Policy Statement: All MediSafe equipment is maintained in accordance with manufacturer recommendations and documented in the asset register. Maintenance records are retained for the life of the equipment. Any repairs involving third party access to MediSafe equipment must be supervised by an IT staff member. Equipment containing sensitive data must be securely wiped before being sent for external repair.

Responsibilities: IT department schedules and oversees all equipment maintenance. The Information Security Officer approves any external repairs involving sensitive data.

Review Date: Annually, next review January 2027.

A.7.14 Secure Disposal or Re use of Equipment

Purpose: To ensure that sensitive information is not recoverable from MediSafe Ltd's equipment when it is disposed of or reassigned.

Scope: Applies to all MediSafe owned equipment being decommissioned, disposed of, or reassigned.

Policy Statement: Before any equipment is disposed of or reused, all data must be securely wiped using certified data destruction methods (minimum DoD 5220.22 M standard or equivalent). Physical destruction is used for storage media that cannot be reliably wiped. Disposal must be carried out by IT staff or a certified third party disposal provider. Disposal certificates must be obtained and retained for a minimum of 3 years for audit purposes.

Responsibilities: IT department manages all equipment disposal and maintains disposal records. The Information Security Officer reviews disposal records annually.

Review Date: Annually, next review January 2027.

A.8 TECHNOLOGICAL CONTROLS

A.8.1 User Endpoint Devices

Purpose: To ensure all devices used by MediSafe Ltd staff are secured, managed, and protected against unauthorised access and malware.

Scope: Applies to all MediSafe owned and approved personal devices used to access MediSafe systems — including laptops, mobile phones, and tablets.

Policy Statement: All MediSafe endpoint devices must be enrolled in the Mobile Device Management (MDM) system before being granted access to MediSafe systems. Devices must have full disk encryption enabled, up to date antivirus installed, and automatic operating system updates configured. Staff must not disable security software or modify device configurations without IT approval. Lost or stolen devices must be reported immediately so remote wipe can be initiated.

Responsibilities: IT department manages MDM enrollment and device configuration. All staff are responsible for maintaining the physical security of their assigned devices.

Review Date: Annually, next review January 2027.

A.8.2 Privileged Access Rights

Purpose: To ensure that privileged access to MediSafe Ltd's systems is strictly controlled, monitored, and limited to authorised individuals.

Scope: Applies to all administrator, superuser, and elevated access accounts across MediSafe's systems, including AWS, databases, and application servers.

Policy Statement: Privileged access rights are granted only to named individuals with a documented business justification, approved by the Information Security Officer. Shared admin accounts are strictly prohibited. Privileged accounts must use MFA and must not be used for day to day activities. All privileged access sessions are logged and reviewed monthly. Privileged access rights are reviewed quarterly and revoked immediately when no longer required.

Responsibilities: IT department manages privileged account provisioning. The Information Security Officer reviews and approves all privileged access requests and conducts quarterly reviews.

Review Date: Annually, next review January 2027.

A.8.3 Information Access Restriction

Purpose: To ensure access to MediSafe Ltd's information assets is restricted to authorised individuals based on their role and business need.

Scope: Applies to all MediSafe systems, applications, and data — including patient health records, financial data, and system configurations.

Policy Statement: Access to MediSafe information assets is granted on a least privilege and need to know basis. Role based access control (RBAC) is implemented across all systems. Clinical staff may access patient records; administrative staff may not. Developers must not have access to live patient data. Access rights are reviewed quarterly and adjusted when a staff member changes role.

Responsibilities: IT department implements and maintains access controls. Line managers request appropriate access for their teams. The Information Security Officer conducts quarterly access reviews.

Review Date: Annually, next review January 2027.

A.8.4 Access to Source Code

Purpose: To protect MediSafe Ltd's application source code from unauthorised access, modification, or theft.

Scope: Applies to all MediSafe source code repositories — including GitHub and any local development environments.

Policy Statement: Access to MediSafe's source code repositories is restricted to authorised developers only. Repository access is granted on a role based basis and reviewed quarterly. All code changes must go through a peer review process before merging. Audit logs of all repository access and changes are retained for a minimum of 12 months. Developers cannot deploy directly to production without approval.

Responsibilities: IT department manages repository access controls. Engineering Lead reviews and approves all access requests. The Information Security Officer reviews access logs quarterly.

Review Date: Annually, next review January 2027.

A.8.5 Secure Authentication

Purpose: To ensure that access to MediSafe Ltd's systems is protected by strong, reliable authentication mechanisms.

Scope: Applies to all MediSafe systems, applications, and cloud services accessed by staff, contractors, and third parties.

Policy Statement: Multi factor authentication (MFA) is mandatory for all MediSafe cloud systems, remote access, and privileged accounts. Passwords must be a minimum of 12 characters containing a mix of uppercase, lowercase, numbers, and special characters. Password reuse is prohibited for the last 10 passwords. Sessions must time out automatically after 15 minutes of inactivity. Single sign on (SSO) is used where available.

Responsibilities: IT department configures and enforces authentication policies across all systems. All staff are responsible for maintaining the security of their credentials and must not share passwords under any circumstances.

Review Date: Annually, next review January 2027.

A.8.6 Capacity Management

Purpose: To ensure MediSafe Ltd's systems have sufficient capacity to meet current and future business needs without compromising availability or performance.

Scope: Applies to all MediSafe systems and infrastructure — including AWS compute, storage, and network resources.

Policy Statement: IT department monitors system capacity on an ongoing basis using AWS CloudWatch. Capacity thresholds are defined for all critical systems — alerts are triggered when usage exceeds 80% of defined limits. Capacity planning reviews are conducted quarterly. AWS auto scaling is configured for critical production systems to handle demand spikes automatically.

Responsibilities: IT department owns capacity monitoring and planning. The Information Security Officer reviews capacity reports quarterly.

Review Date: Annually, next review January 2027.

A.8.7 Protection Against Malware

Purpose: To protect MediSafe Ltd's systems and data from malware, ransomware, and other malicious software.

Scope: Applies to all MediSafe endpoint devices, servers, and email systems.

Policy Statement: All MediSafe endpoint devices must have up to date antivirus and anti malware software installed and actively running at all times. Email filtering is configured to scan all inbound and outbound emails for malicious attachments and links. Staff must not disable security software. Suspicious emails must be reported to IT immediately. Malware detection events are logged, investigated, and reported to the Information Security Officer within 24 hours.

Responsibilities: IT department deploys and maintains malware protection across all systems. All staff are responsible for reporting suspicious activity.

Review Date: Annually, next review January 2027.

A.8.8 Management of Technical Vulnerabilities

Purpose: To identify and remediate technical vulnerabilities in MediSafe Ltd's systems before they can be exploited.

Scope: Applies to all MediSafe systems, applications, cloud infrastructure, and third party software components.

Policy Statement: MediSafe conducts automated vulnerability scans on all systems monthly and following any significant change. Critical vulnerabilities must be patched within 48 hours of identification. High severity vulnerabilities must be remediated within 7 days. Medium and low severity vulnerabilities are addressed within 30 days. AWS Inspector is used for cloud infrastructure vulnerability scanning.

Responsibilities: IT department conducts vulnerability scanning and manages patching. The Information Security Officer reviews scan results and tracks remediation.

Review Date: Annually, next review January 2027.

A.8.9 Configuration Management

Purpose: To ensure MediSafe Ltd's systems are configured securely and consistently, reducing the risk of misconfiguration related vulnerabilities.

Scope: Applies to all MediSafe systems, cloud infrastructure, network devices, and endpoint devices.

Policy Statement: All MediSafe systems must be configured in accordance with documented security baselines before deployment. Default passwords must be changed immediately on all new systems. Unnecessary services, ports, and features must be disabled. Configuration changes must go through the formal change management process. AWS Security Hub is used to monitor cloud configuration compliance continuously.

Responsibilities: IT department owns system configuration standards and baselines. The Information Security Officer reviews configuration compliance reports quarterly.

Review Date: Annually, next review January 2027.

A.8.10 Information Deletion

Purpose: To ensure that MediSafe Ltd's information assets — including patient data — are deleted securely and in line with defined retention schedules when no longer required.

Scope: Applies to all MediSafe data across all systems, databases, backup media, and physical storage.

Policy Statement: MediSafe maintains a Data Retention Policy defining retention periods for all data categories — patient health records are retained for 8 years in line with Irish healthcare regulations. Data that has exceeded its retention period must be deleted securely using certified methods. Deletion of patient data is logged and documented for audit purposes. GDPR erasure requests are processed within 30 days.

Responsibilities: IT department manages data deletion processes and retention schedules. The Information Security Officer reviews deletion logs annually. Legal team advises on regulatory retention requirements.

Review Date: Annually, next review January 2027.

A.8.11 Data Masking

Purpose: To protect patient and sensitive data from unnecessary exposure in non production environments.

Scope: Applies to all MediSafe development, testing, and QA environments where data processing occurs.

Policy Statement: Real patient data must never be used in development, testing, or QA environments under any circumstances. All test data must be synthetically generated or anonymised before use. Data masking techniques — including pseudonymisation, tokenisation, and data substitution — must be applied to any dataset used outside the production environment. Compliance is verified by the Information Security Officer during quarterly environment reviews.

Responsibilities: Engineering Lead is responsible for ensuring data masking is applied in all non production environments. The Information Security Officer conducts quarterly verification reviews.

Review Date: Annually, next review January 2027.

A.8.12 Data Leakage Prevention

Purpose: To prevent unauthorised transfer or disclosure of MediSafe Ltd's sensitive data — including patient health records.

Scope: Applies to all MediSafe systems, devices, email, and data transfer channels.

Policy Statement: MediSafe implements Data Loss Prevention (DLP) controls to detect and prevent unauthorised transmission of sensitive data. Patient data must not be sent via personal email, unencrypted channels, or unauthorised cloud storage services. USB data transfer is disabled on MediSafe devices unless specifically approved. Screen capture of patient data is prohibited outside of approved workflows. DLP alerts are reviewed by IT within 24 hours of triggering.

Responsibilities: IT department implements and monitors DLP controls. The Information Security Officer reviews DLP incidents and updates policies accordingly.

Review Date: Annually, next review January 2027.

A.8.13 Information Backup

Purpose: To ensure MediSafe Ltd's critical data can be recovered in the event of data loss, system failure, or a security incident.

Scope: Applies to all critical MediSafe data — including patient health records, system configurations, application data, and databases.

Policy Statement: Automated daily backups are taken of all critical MediSafe systems and data. Backups are encrypted using AES 256 and stored in a separate AWS region from the primary production environment. Backup integrity is tested monthly through restore testing. Patient data backups are retained for 30 days. Backup access is restricted to named IT staff only.

Responsibilities: IT department owns backup configuration, monitoring, and testing. The Information Security Officer reviews backup test results quarterly.

Review Date: Annually, next review January 2027.

A.8.14 Redundancy of Information Processing Facilities

Purpose: To ensure MediSafe Ltd's critical systems remain available in the event of a single point of failure.

Scope: Applies to all MediSafe critical systems and infrastructure hosted on AWS.

Policy Statement: MediSafe's critical production systems are deployed across multiple AWS Availability Zones to ensure high availability. Load balancing is configured to distribute traffic across redundant instances. Recovery Time Objective (RTO) for critical systems is 4 hours. Recovery Point Objective (RPO) is 24 hours. Redundancy configurations are tested semi annually.

Responsibilities: IT department designs and maintains redundancy configurations. The Information Security Officer reviews failover test results semi annually.

Review Date: Annually, next review January 2027.

A.8.15 Logging

Purpose: To maintain a complete and tamper proof audit trail of security relevant events across MediSafe Ltd's systems.

Scope: Applies to all MediSafe systems, cloud infrastructure, applications, and network devices.

Policy Statement: Security event logging is enabled across all MediSafe systems. Logs must capture — at minimum — user login and logout events, access to patient data, privileged account activity, system configuration changes, and failed authentication attempts. AWS CloudTrail is enabled across all AWS accounts and regions. Logs are stored in a tamper proof, write once S3 bucket. Log retention period is a minimum of 12 months.

Responsibilities: IT department configures and maintains logging across all systems. The Information Security Officer reviews log configurations quarterly.

Review Date: Annually, next review January 2027.

A.8.16 Monitoring Activities

Purpose: To detect and respond to suspicious activity, anomalies, and potential security incidents across MediSafe Ltd's systems in a timely manner.

Scope: Applies to all MediSafe systems, cloud infrastructure, and network traffic.

Policy Statement: MediSafe implements continuous monitoring of all critical systems using AWS CloudWatch and Security Hub. Automated alerts are configured for suspicious activities — including multiple failed login attempts, unusual data access patterns, and configuration changes outside approved change windows. Security alerts are triaged by IT within 1 hour of triggering during business hours and within 4 hours outside business hours.

Responsibilities: IT department manages monitoring tools and responds to automated alerts. The Information Security Officer conducts monthly log reviews.

Review Date: Annually, next review January 2027.

A.8.17 Clock Synchronisation

Purpose: To ensure consistent and accurate timestamps across all MediSafe Ltd's systems for effective log correlation and incident investigation.

Scope: Applies to all MediSafe systems, servers, and network devices.

Policy Statement: All MediSafe systems must synchronise their clocks using Network Time Protocol (NTP) with a reliable time source. AWS systems use Amazon Time Sync Service by default. On premises devices are configured to synchronise with an approved NTP server. Clock synchronisation is verified monthly. Any clock drift exceeding 1 second must be investigated and corrected immediately.

Responsibilities: IT department configures and monitors NTP synchronisation across all systems.

Review Date: Annually, next review January 2027.

A.8.18 Use of Privileged Utility Programs

Purpose: To control the use of system utility programs that could bypass MediSafe Ltd's security controls if misused.

Scope: Applies to all system administration tools, diagnostic utilities, and programs with elevated system access on MediSafe infrastructure.

Policy Statement: Use of privileged utility programs is restricted to named IT staff with documented approval. All use must be logged and the logs reviewed monthly. Privileged utilities must not be installed on standard user devices. Temporary access must be time limited and revoked immediately upon completion of the approved task.

Responsibilities: IT department manages access to and use of privileged utility programs. The Information Security Officer reviews usage logs monthly.

Review Date: Annually, next review January 2027.

A.8.19 Installation of Software on Operational Systems

Purpose: To prevent the installation of unauthorised, unlicensed, or malicious software on MediSafe Ltd's systems.

Scope: Applies to all MediSafe owned and managed devices and servers.

Policy Statement: Only IT approved software may be installed on MediSafe systems. Staff do not have local administrator rights and cannot install software without IT approval. All software must be sourced from official vendors or approved repositories. All installed software is tracked in the asset register and reviewed quarterly for licence compliance and security updates.

Responsibilities: IT department manages the software approval process and asset register. All staff must submit software requests through the approved IT helpdesk channel.

Review Date: Annually, next review January 2027.

A.8.20 Network Security

Purpose: To protect MediSafe Ltd's networks from unauthorised access, attack, and data interception.

Scope: Applies to all MediSafe networks — including AWS VPC, office network, Wi Fi, and remote access infrastructure.

Policy Statement: MediSafe's AWS environment is deployed within a Virtual Private Cloud (VPC) with strict firewall rules controlling inbound and outbound traffic. Only required ports and protocols are permitted — all others are blocked by default. Guest Wi Fi is on a separate network segment with no access to internal systems. Intrusion detection is enabled via AWS GuardDuty. All remote access requires VPN.

Responsibilities: IT department designs, maintains, and monitors network security controls. The Information Security Officer reviews network configuration quarterly.

Review Date: Annually, next review January 2027.

A.8.21 Security of Network Services

Purpose: To ensure all network services used by MediSafe Ltd are secured against unauthorised access and interception.

Scope: Applies to all MediSafe network services — including APIs, web services, cloud connections, and third party integrations.

Policy Statement: All MediSafe APIs and web services must enforce TLS 1.2 or higher for all data in transit. API authentication is enforced via OAuth 2.0 or equivalent. API keys and tokens must be rotated at least every 90 days and must not be hardcoded in source code. Third party network service providers must demonstrate equivalent security standards via their SOC 2 or ISO 27001 certification.

Responsibilities: Engineering Lead is responsible for API and web service security. IT department manages network service configurations. The Information Security Officer reviews network service security annually.

Review Date: Annually, next review January 2027.

A.8.22 Segregation of Networks

Purpose: To limit the impact of a security breach by separating MediSafe Ltd's network into distinct segments based on data sensitivity and function.

Scope: Applies to all MediSafe network infrastructure — including AWS VPC, office networks, and development environments.

Policy Statement: MediSafe's network is segmented into clearly defined zones — production (patient data systems), development, corporate office, and guest Wi Fi. Traffic between segments is controlled by firewall rules on a whitelist basis. Patient data systems are isolated in a dedicated VPC subnet with no direct internet access. Development environments have no connectivity to production patient data.

Responsibilities: IT department designs and maintains network segmentation. The Information Security Officer reviews segmentation annually.

Review Date: Annually, next review January 2027.

A.8.23 Web Filtering

Purpose: To protect MediSafe Ltd's staff and systems from web based threats and inappropriate content.

Scope: Applies to all MediSafe staff accessing the internet via MediSafe's corporate network or VPN.

Policy Statement: MediSafe implements DNS based web filtering to block access to known malicious websites, phishing domains, and inappropriate content categories. Web filtering applies to all corporate network traffic and VPN connected remote workers. Staff may not use personal hotspots or unfiltered connections for MediSafe work on company devices. Web filtering logs are reviewed monthly by IT.

Responsibilities: IT department configures and maintains web filtering controls. The Information Security Officer reviews filtering logs monthly.

Review Date: Annually, next review January 2027.

A.8.24 Use of Cryptography

Purpose: To ensure MediSafe Ltd's sensitive information — particularly patient health data — is protected through consistent and effective use of cryptography.

Scope: Applies to all MediSafe data at rest, data in transit, and backup data.

Policy Statement: All patient data and sensitive information must be encrypted at rest using AES 256 encryption. All data in transit must be encrypted using TLS 1.2 or higher — unencrypted transmission of sensitive data is strictly prohibited. Encryption keys are managed using AWS Key Management Service (KMS) and rotated annually. Backup data is encrypted before storage. Cryptographic algorithms are reviewed annually.

Responsibilities: IT department implements and maintains cryptographic controls. The Information Security Officer reviews encryption standards annually.

Review Date: Annually, next review January 2027.

A.8.25 Secure Development Lifecycle

Purpose: To ensure information security is embedded throughout MediSafe Ltd's software development lifecycle.

Scope: Applies to all MediSafe software development activities — including new features, bug fixes, and third party integrations.

Policy Statement: Security requirements must be defined at the start of every development project. Threat modelling is conducted for all significant new features. Security code reviews are mandatory before merging any code. Static Application Security Testing (SAST) tools are run automatically on all pull requests. All developers must complete secure coding training annually.

Responsibilities: Engineering Lead owns the secure development lifecycle process. IT department manages security testing tools. The Information Security Officer reviews SDLC compliance quarterly.

Review Date: Annually, next review January 2027.

A.8.26 Application Security Requirements

Purpose: To ensure that security requirements are defined, documented, and met for all MediSafe Ltd applications before development begins.

Scope: Applies to all MediSafe applications — including the patient facing web and mobile app, internal admin dashboard, and any third party integrations.

Policy Statement: Security requirements must be documented in the functional specification for every new application or significant feature. Requirements must cover authentication, authorisation, data validation, error handling, session management, and audit logging. Security requirements are reviewed and approved by the Information Security Officer before development commences.

Responsibilities: Engineering Lead documents application security requirements. The Information Security Officer reviews and approves requirements before development begins.

Review Date: Annually, next review January 2027.

A.8.27 Secure System Architecture and Engineering Principles

Purpose: To ensure MediSafe Ltd's systems are designed and built with security principles embedded from the ground up.

Scope: Applies to all MediSafe system design and architecture decisions.

Policy Statement: MediSafe applies the following security engineering principles to all system design: least privilege, defence in depth, fail secure, zero trust, and separation of duties. Architecture decisions are reviewed by the Information Security Officer before implementation. Security architecture is reviewed annually.

Responsibilities: Engineering Lead is responsible for applying security architecture principles. The Information Security Officer reviews architecture decisions and conducts annual reviews.

Review Date: Annually, next review January 2027.

A.8.28 Secure Coding

Purpose: To prevent common software vulnerabilities from being introduced into MediSafe Ltd's applications through insecure coding practices.

Scope: Applies to all MediSafe development staff and contractors writing code for MediSafe applications.

Policy Statement: All MediSafe developers must follow the OWASP Secure Coding Guidelines. Code must be protected against the OWASP Top 10 vulnerabilities — including SQL injection, cross site scripting (XSS), insecure authentication, and sensitive data exposure. All code changes require peer review by at least one other developer before merging. Automated static code analysis is run on all pull requests.

Responsibilities: Engineering Lead enforces secure coding standards. IT department manages automated code analysis tools. The Information Security Officer reviews secure coding compliance annually.

Review Date: Annually, next review January 2027.

A.8.29 Security Testing in Development and Acceptance

Purpose: To identify and remediate security vulnerabilities before MediSafe Ltd's applications are deployed to production.

Scope: Applies to all MediSafe applications and system changes prior to production deployment.

Policy Statement: Security testing is mandatory before any new application or significant change is deployed to production. Testing includes automated vulnerability scanning, static code analysis, and manual security review. Penetration testing is conducted annually by a qualified third party provider. All critical and high severity findings must be remediated before deployment.

Responsibilities: Engineering Lead schedules and oversees security testing. The Information Security Officer reviews penetration test results and approves production deployment sign off.

Review Date: Annually, next review January 2027.

A.8.30 Outsourced Development

Purpose: To ensure that software developed by third parties on behalf of MediSafe Ltd meets the same security standards as internally developed software.

Scope: Applies to all third party developers, agencies, and contractors engaged to develop software for MediSafe Ltd.

Policy Statement: All outsourced development contracts must include MediSafe's secure coding requirements, data protection obligations, and the right to conduct security reviews. Third party developers must not access live patient data. Code produced by third parties is subject to the same security review and testing process as internally developed code before deployment. MediSafe retains ownership of all code developed on its behalf.

Responsibilities: Legal team ensures security obligations are included in outsourced development contracts. Engineering Lead oversees code quality and security reviews for third party code.

Review Date: Annually, next review January 2027.

A.8.31 Separation of Development, Test and Production Environments

Purpose: To prevent unauthorised changes, data exposure, and instability in MediSafe Ltd's production environment.

Scope: Applies to all MediSafe development, testing, staging, and production environments.

Policy Statement: MediSafe maintains fully separate development, testing, and production environments on AWS. Access to the production environment is restricted to named operations staff only — developers do not have direct production access. Deployments to production must go through a formal release management process including testing and approval sign off. Real patient data must never be present in development or test environments.

Responsibilities: IT department maintains environment separation and access controls. Engineering Lead manages the release process. The Information Security Officer verifies environment separation quarterly.

Review Date: Annually, next review January 2027.

A.8.32 Change Management

Purpose: To ensure that all changes to MediSafe Ltd's systems are planned, approved, tested, and documented to prevent unintended disruption or security vulnerabilities.

Scope: Applies to all changes to MediSafe's systems, applications, infrastructure, and configurations.

Policy Statement: All changes to MediSafe systems must go through the formal Change Management process. Changes are classified as Standard (pre approved, low risk), Normal (requires review and approval), or Emergency (requires post implementation review). All changes must be documented with a description, risk assessment, rollback plan, and approval sign off. Emergency changes must be reviewed and approved retrospectively within 24 hours.

Responsibilities: IT department owns the Change Management process. The Information Security Officer reviews all Normal and Emergency changes. Engineering Lead approves application level changes.

Review Date: Annually, next review January 2027.

A.8.33 Test Information

Purpose: To ensure that test data used in MediSafe Ltd's non production environments does not expose real patient or sensitive information.

Scope: Applies to all MediSafe development, testing, and QA environments.

Policy Statement: Real patient data must never be used as test data under any circumstances. Test data must be synthetically generated or anonymised before use. Any test data derived from production data must be approved by the Information Security Officer and fully anonymised. Test datasets are reviewed quarterly to ensure no real patient data has been inadvertently introduced.

Responsibilities: Engineering Lead is responsible for managing test data. The Information Security Officer approves any test data derived from production and conducts quarterly reviews.

Review Date: Annually, next review January 2027.

A.8.34 Protection of Information Systems During Audit Testing

Purpose: To ensure that audit and penetration testing activities do not cause unintended disruption, data exposure, or security incidents within MediSafe Ltd's systems.

Scope: Applies to all audit, penetration testing, and vulnerability assessment activities conducted on MediSafe's systems.

Policy Statement: All audit and penetration testing activities must be formally planned, scoped, and approved by the Information Security Officer before commencement. Testing must be conducted in a controlled manner to avoid unintended system disruption or data exposure. Production systems may only be tested during agreed maintenance windows with IT oversight. Third party testers must sign NDAs and operate within a defined scope of work.

Responsibilities: The Information Security Officer approves and oversees all audit and penetration testing activities. IT department provides technical support and monitors systems during testing.

Review Date: Annually, next review January 2027.

GLOSSARY

Term	Definition
AES 256	Advanced Encryption Standard with 256 bit key — industry standard for data encryption at rest
AWS	Amazon Web Services — MediSafe's cloud infrastructure provider
GDPR	General Data Protection Regulation — EU regulation governing the processing of personal data
HIPAA	Health Insurance Portability and Accountability Act — US regulation for protecting patient health information
ISMS	Information Security Management System — the overall framework of policies and controls for managing information security
ISO 27001	International standard for information security management systems
MFA	Multi Factor Authentication — requiring two or more forms of verification to access a system
MDM	Mobile Device Management — software for managing and securing mobile devices
NDA	Non Disclosure Agreement — a legal contract protecting confidential information
OWASP	Open Web Application Security Project — organisation providing free security resources and guidelines
PII	Personally Identifiable Information — any data that can identify an individual
RBAC	Role Based Access Control — granting system access based on a user's role within the organisation
RPO	Recovery Point Objective — maximum acceptable data loss in the event of a disruption
RTO	Recovery Time Objective — maximum acceptable time to restore systems after a disruption
SAST	Static Application Security Testing — automated tool for finding security vulnerabilities in source code
SOC 2	Service Organisation Control 2 — security audit framework for technology companies
TLS	Transport Layer Security — cryptographic protocol for securing data in transit
VPC	Virtual Private Cloud — isolated network environment within AWS
VPN	Virtual Private Network — encrypted tunnel for secure remote access to MediSafe systems